

케이뱅크플러스 오픈뱅킹 API 게이트웨이 구축 과업지시서

문서번호	KBP-2027-SOW-114
발주사	주식회사 케이뱅크플러스 (디지털사업본부 오픈뱅킹추진팀)
사업명	오픈뱅킹 API 게이트웨이 구축
작성일	2026년 11월 20일
문서 성격	기준 문서 — 본 사업의 과업 범위를 정하는 정보

1. 사업 개요

1.1 추진 배경

당행은 2019년 상용 장비 기반 게이트웨이로 오픈뱅킹 대외 채널을 열었다. 개통 당시 연동 기관은 11개사였으나 현재 제휴 핀테크사 68개사가 붙어 있고, 일 평균 API 호출 2,340만 건을 처리한다. 장비의 공표 처리 한계는 초당 1,600건인데 급여일이 몰리는 매월 25일 오전 9시부터 11시 사이에 이 값을 넘긴다.

2026년 한 해 동안 대외 채널 장애는 4건 발생했고 누적 중단 3시간 47분을 기록했다. 네 건 모두 특정 기관의 조회성 호출이 몰리면서 다른 기관의 이체 요청까지 함께 밀린 사례다. 현행 장비는 기관 단위 유량 제어를 지원하지 않아 한 기관의 호출 폭주를 그 기관 안에서 막을 수단이 없다.

과금 역시 문제다. 기관별 호출 건수는 장비 로그를 월 마감 후 내려받아 수작업으로 집계하며, 명세를 확정하는 데 매월 5영업일이 걸린다. 집계 근거가 로그 파일뿐이라 기관이 건수에 이의를 제기하면 대조에 다시 며칠이 든다.

1.2 사업 목적

- 대외 호출의 단일 진입점을 두고 기관 단위로 유량을 제어한다.
- 기관 인증과 사용자 동의 권한을 표준 방식으로 다시 세운다.

- 호출 건수 집계를 시스템화하여 과금 근거를 자동으로 남긴다.
- 제휴 기관이 스스로 규격을 확인하고 시험할 수 있는 창구를 연다.
- 레거시 v1 규격을 정리하여 원장 변경 없이 대외 규격만 바꿀 수 있게 한다.

1.3 사업 기간 및 예산

사업 기간	2027년 1월 11일 ~ 2027년 9월 30일
총 사업비	금 십사억삼천만원정 (₩1,430,000,000, 부가세 별도)
수행 장소	서울특별시 중구 케이뱅크플러스 본점 8층 상주
대금 지급	착수 20% / 1차 중도 30% / 2차 중도 30% / 잔금 20%
지급 조건	각 회차의 지급 조건은 별첨 「일정 계획서」의 마일스톤을 따른다.

2. 현행 시스템 현황

구분	현행	비고
게이트웨이	상용 장비 GW-7200 2대 (2019년 도입)	처리 한계 초당 1,600건, 유지보수 2027년 12월 종료
인증	자체 토큰 서버, 기관별 공유 비밀키	키 회수·폐기 절차 없음
대외 API	레거시 REST 41종 (v1)	규격 문서 최신본이 2021년판
과금	월 마감 후 로그 수작업 집계	명세 확정까지 5영업일
관제	장비 자체 대시보드	기관·호출 단위 추적 불가
인프라	금융망 내 물리 서버 12대	이중화는 게이트웨이 계층에만 적용
원장 연계	계정계 전문 연계 (MCI 경유)	본 사업에서 계정계는 변경하지 않는다

3. 과업 범위

본 장이 수행사가 만들어 내야 할 결과물과 그것을 만드는 과업을 정한다. 과업 번호 G-01 부터 G-06 까지는 본 사업의 모든 문서에서 같은 뜻으로 쓴다. 과업별 공수와 선행 관계, 일정은 별첨 「일정 계획서」 제2장을, 요구사항 항목과 완료 기준은 「요구사항 정의서」를, 대외 규격·오류 코드·유량 한도는 「API 설계서」를, 보안 통제 항목과 증빙은 「보안 요구사항서」를 따른다. 본 문서는 그 값들을 다시 적지 않는다.

3.1 (G-01) API 게이트웨이 신규 구축

대외 호출이 반드시 지나가는 단일 진입점을 새로 만든다. 라우팅·인증·유량 제어·기록이 이 계층에서 끝나야 하며, 원장과 계정계는 손대지 않는다.

- 라우팅 규칙 정의 및 무중단 반영 체계
- 백엔드 장애 격리(회로 차단) 및 대체 응답 규칙
- 호출 추적 ID 부여와 요청·응답 전문 기록
- 기존 장비에서 신규 게이트웨이로의 트래픽 전환 절차

3.2 (G-02) 인증·권한 체계 재구축

기관별 공유 비밀키 방식을 걷어내고 기관 인증과 사용자 동의를 분리한다. 동의 범위를 벗어난 호출은 게이트웨이에서 막는다.

- 기관 인증서 발급·회수·폐기 절차 정립
- 사용자 동의 등록·갱신·철회 기능
- 권한 범위(스코프) 체계 정의와 검증
- 토큰 발급·폐기 및 전파

3.3 (G-03) 유량 제어 및 과금 산정

기관 단위로 초당·일 단위 한도를 두고 초과 호출을 거부한다. 성공 응답 건수를 근거로 과금 명세를 자동 산정하여 수작업 집계를 없앤다.

- 기관 등급 체계와 한도 적용
- 한도 초과 시 거부·회신 처리
- 호출 건수 집계와 월 과금 명세 산출
- 기관별 사용량 조회 화면

3.4 (G-04) 개발자 포털 구축

제휴 기관이 규격을 확인하고 모의 시험을 돌리는 창구를 만든다. 규격 문서를 사람이 따로 관리하지 않도록 게이트웨이 정의에서 자동 생성한다.

- API 규격 문서 자동 생성·공개
- 모의 데이터 기반 샌드박스 제공
- 기관 담당자용 키 발급·재발급 창구
- 공지·변경 이력 게시

3.5 (G-05) 레거시 API 이전

레거시 REST 41종을 신규 규격으로 옮긴다. 기관이 한 번에 넘어올 수 없으므로 이전 기간에는 두 규격을 함께 제공하고, 기관별 전환 일정을 따로 관리한다.

- v1 대 v2 매핑표 작성 및 발주사 확인
- 병행 제공 구간의 응답 동등성 검증
- 기관별 전환 안내와 전환 실적 관리
- v1 종료 절차

3.6 (G-06) 통합 관제 및 시험

호출을 기관·API 단위로 들여다보는 관제 화면을 만들고, 성능·장애·보안 시험을 수행한다. 시험 통과 기준은 「요구사항 정의서」의 완료 기준을 그대로 쓴다.

- 기관·API 단위 호출 현황 및 경보
- 성능 부하시험 및 장애 주입 시험
- 보안 통제 증빙 수집과 모의해킹 대응
- 운영 인수인계 및 장애 대응 지침서 작성

4. 산출물 및 검수 기준

단계	산출물	검수 기준
분석	현행 호출 분석서, 요구사항 추적표	요구사항 전건이 추적표에서 과업에 대응
설계	게이트웨이 설계서, API 설계서, 보안 요구사항서	발주사 설계 검토 승인
개발	소스코드, 단위시험 결과서	단위시험 통과율 100%
시험	부하시험 결과서, 장애 주입 시험 결과서	비기능 요구사항 전건 충족
보안	보안 통제 증빙철, 모의해킹 결과 보고서	상위 등급 결함 조치 완료
이전	v1-v2 매핑표, 기관별 전환 실적표	매핑 미대응 항목 0건
종료	운영자 지침서, 장애 대응 지침서	운영 인수인계 확인서

5. 제약사항

- 계정계와 원장은 본 사업의 변경 대상이 아니다. 필요한 변경은 발주사 계정계팀에 요청하고 별도 일정으로 처리한다.
- 개발·시험 환경은 금융망 안에 두며 외부망과 물리적으로 분리한다. 반출은 발주사 승인 절차를 거친다.
- 운영 반영은 일요일 00시 30분부터 04시 30분까지만 한다. 이 창은 주 1회뿐이다.
- 반기 결산 기간인 2027년 6월 29일부터 7월 3일까지는 어떤 운영 반영도 하지 않는다.
- 대외 채널은 무중단이 원칙이다. 전환은 기관 단위 부분 전환으로 하고 전면 절체는 하지 않는다.
- 시험용 설계와 데이터는 반출할 수 없다. 샌드박스는 모의 데이터로만 구성한다.

6. 사업관리 요구사항

아래는 사업 관리 절차이며 과업(제3장)과 구분한다.

- 주간 보고는 매주 화요일 10시에 제출하며 진척·위험·다음 주 계획을 포함한다.
- 단계별 산출물은 제출 후 15영업일 이내에 검수한다.

- 투입 인력 전원은 금융보안 교육과 본점 출입 절차를 이수한다.
- 투입 인력 교체는 교체 예정일 10영업일 전에 발주사 승인을 받는다.
- 하자보수는 최종 검수일로부터 24개월이다.

본 문서는 과업의 범위를 정할 뿐 수치 기준을 정하지 않는다. 성능·보안·일정 수치가 본 문서와 별첨 문서에서 다르게 보이면 별첨 문서를 정본으로 본다.